NAME: BENITA WILSON
SRN:PES2UG24CS111
SUBJECT : SE LAB-05

```
(venv) PS C:\Users\DELL\L5_45_ticket_booking_system> Get-Content .\bandit_report.txt
Run started:2026-10-14 06:22:06.134169+00:00

Test results:
>> Issue: [B110:try_except_pass] Try, Except, Pass detected.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html
   Location: .\.\ticket_booking_system.py:26:4
25              theater_seats[seat_id]["is_sold"] = False
26          except:
27              pass
28

--------------------------------------------------
>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
   Severity: Medium   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval
   Location: .\.\ticket_booking_system.py:42:18
41          base_price = theater_seats[seat_id]["price"]
42          final_price = eval(promo_expr)
43          return final_price

--------------------------------------------------
>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False
   Severity: High   Confidence: High
```

```
>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False
   Severity: High   Confidence: High
   CWE: CWE-327 (https://cwe.mitre.org/data/definitions/327.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html
   Location: .\.\ticket_booking_system.py:47:11
46      def generate_ticket_hash(ticket_code):
47          return hashlib.md5(ticket_code.encode()).hexdigest()
48

--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: .\.\ticket_booking_system.py:51:11
50      def generate_booking_pin():
51          return random.randint(1000, 9999)
52

--------------------------------------------------
>> Issue: [B605:start_process_with_a_shell] Starting a process with a shell, possible injection detected, security is
sue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b605_start_process_with_a_shell.html
   Location: .\.\ticket_booking_system.py:58:4
57          f.close()
58          os.system("echo Seating chart exported to: " + filename)
```

```
--------------------------------------------------

Code scanned:
        Total lines of code: 60
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 2
                Medium: 1
                High: 2
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 5
Files skipped (0):
```

Pylint and Flake8:-

```
(venv) PS C:\UserGet-Content .\pylint_report.txttem>
************* Module ticket_booking_system
ticket_booking_system.py:82:0: C0304: Final newline missing (missing-final-newline)
ticket_booking_system.py:15:0: C0116: Missing function or method docstring (missing-function-docstring)
ticket_booking_system.py:15:0: C0103: Function name "reserveSeat" doesn't conform to snake_case naming style (invalid
-name)
ticket_booking_system.py:15:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
ticket_booking_system.py:19:25: C0209: Formatting a regular string which could be an f-string (consider-using-f-strin
g)
ticket_booking_system.py:23:0: C0116: Missing function or method docstring (missing-function-docstring)
ticket_booking_system.py:26:4: W0702: No exception type(s) specified (bare-except)
ticket_booking_system.py:30:0: C0116: Missing function or method docstring (missing-function-docstring)
ticket_booking_system.py:32:7: C0121: Comparison 'theater_seats.get(seat_id) == None' should be 'theater_seats.get(se
at_id) is None' (singleton-comparison)
ticket_booking_system.py:34:4: R1703: The if statement can be replaced with 'return bool(test)' (simplifiable-if-stat
ement)
ticket_booking_system.py:34:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code ins
ide it (no-else-return)
ticket_booking_system.py:31:4: W0612: Unused variable 'booking_fee' (unused-variable)
ticket_booking_system.py:40:0: C0116: Missing function or method docstring (missing-function-docstring)
ticket_booking_system.py:42:18: W0123: Use of eval (eval-used)
ticket_booking_system.py:41:4: W0612: Unused variable 'base_price' (unused-variable)
ticket_booking_system.py:46:0: C0116: Missing function or method docstring (missing-function-docstring)
ticket_booking_system.py:50:0: C0116: Missing function or method docstring (missing-function-docstring)
ticket_booking_system.py:54:0: C0116: Missing function or method docstring (missing-function-docstring)
ticket_booking_system.py:55:8: W1514: Using open without explicitly specifying an encoding (unspecified-encoding)
ticket_booking_system.py:55:8: R1732: Consider using 'with' for resource-allocating operations (consider-using-with)
ticket_booking_system.py:61:0: C0116: Missing function or method docstring (missing-function-docstring)
ticket_booking_system.py:61:24: W0621: Redefining name 'theater_seats' from outer scope (line 8) (redefined-outer-nam
e)
ticket_booking_system.py:63:8: W0612: Unused variable 'seat' (unused-variable)
```

```
e)
ticket_booking_system.py:63:8: W0612: Unused variable 'seat' (unused-variable)
ticket_booking_system.py:69:0: C0116: Missing function or method docstring (missing-function-docstring)
ticket_booking_system.py:6:0: W0611: Unused import math (unused-import)

-----------------------------------
Your code has been rated at 5.37/10

(venv) PS C:\Users\DELL\L5_45_ticket_booking_system> Get-Content .\flake8_report.txt
.\ticket_booking_system.py:6:1: F401 'math' imported but unused
.\ticket_booking_system.py:19:80: E501 line too long (82 > 79 characters)
.\ticket_booking_system.py:26:5: E722 do not use bare 'except'
.\ticket_booking_system.py:31:5: F841 local variable 'booking_fee' is assigned to but never used
.\ticket_booking_system.py:32:35: E711 comparison to None should be 'if cond is None:'
.\ticket_booking_system.py:41:5: F841 local variable 'base_price' is assigned to but never used
.\ticket_booking_system.py:82:7: W292 no newline at end of file
(venv) PS C:\Users\DELL\L5_45_ticket_booking_system>
```

1. Bandit final report:-

```
(venv) PS C:\Users\DELL\L5_45_ticket_booking_system> Get-Content .\bandit_report.txt
Run started:2026-10-14 06:39:30.263882+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 75
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):
```

2. Pylint final report

```
(venv) PS C:\Users\DELL\L5_45_ticket_booking_system> Get-Content .\pylint_report.txt

 --------------------------------------------------------------------
 Your code has been rated at 10.00/10 (previous run: 9.83/10, +0.17)
```

3.Flake8 final report

```
(venv) PS C:\Users\DELL\L5_45_ticket_booking_system> python -m flake8 .\ticket_booking_system.py
(venv) PS C:\Users\DELL\L5_45_ticket_booking_system>
```

4.Program execution

```
(venv) PS C:\Users\DELL\L5_45_ticket_booking_system> python .\ticket_booking_system.py
Is B1 available: True
Promo price: 16.0
Ticket Hash: 3fab8fc159f6c8f4d993cfca213b143587ff0137b6bbd488716b060a1a33ab80
Ticket verification: True
Booking PIN: 1450
Seating chart exported to: seating_chart.txt
Sold count: 1
(venv) PS C:\Users\DELL\L5_45_ticket_booking_system>
```

Lab 5: Static Code Analysis

Supplementary Documentation

Name: Benita Wilson **SRN:** PES2UG24CS111

This supplement adds the issue log and reflection section to the original evidence PDF. The submitted screenshots show analysis of **ticket_booking_system.py**. The issue descriptions below are based on the findings visible in the original report screenshots; the fix approaches describe the corresponding remediation to document.

1. Issue Identification and Fix Table

Issue / tool finding	Type	Description	Fix approach / resolution
Mutable default argument (Pylint)	Bug / maintainability	A function uses a mutable object such as a list or dictionary as a default argument. The same object can be shared between calls.	Use None as the default, then create a fresh list or dictionary inside the function.
Bare or overly broad except (Pylint)	Reliability	A broad exception handler can hide unexpected errors and make debugging difficult.	Catch the specific exception types expected; handle or log them clearly.
Weak MD5 hash (Bandit B324)	Security — high	MD5 is not suitable for security-sensitive hashing.	Remove MD5 from security-sensitive use. Use an appropriate modern cryptographic hash or a password-hashing method if handling passwords. The final Bandit screenshot reports no remaining findings.
Pseudo-random PIN generation (Bandit B311)	Security	The standard random module is not designed for security-sensitive values such as booking PINs.	Use secrets.randbelow() or another cryptographically secure generator for PINs. The final Bandit screenshot reports no remaining findings.
Shell command construction (Bandit B605)	Security — high	Starting a shell with a constructed command can create command-injection risk.	Prefer subprocess.run() with a list of arguments and shell=False; avoid concatenating untrusted input into commands. The final Bandit screenshot reports no remaining findings.
Unused imports / unused variables (Pylint, Flake8)	Code quality	Unused names make code harder to read and can indicate incomplete or unnecessary code.	Remove unused imports and variables, or use the values if they are required.
Line too long (Flake8 E501)	Style	A line exceeds the configured maximum line length.	Break the statement across multiple lines while preserving readability.
Missing final newline / missing docstrings (Pylint)	Style / maintainability	The report flags a missing final newline and missing module/function docstrings.	Add a newline at the end of the file and concise docstrings where appropriate.

Verification evidence in the original PDF: the Bandit screenshot displays “No issues identified,” and the Pylint screenshot displays a score of 10.00/10. The Flake8 command is visible, but its clean output is not clearly legible in the supplied screenshot. If available, include a fresh screenshot showing the final Flake8 command and its output.

2. Reflection

Q1. Which issues were the easiest to fix, and which were the hardest? Why?
The easiest issues were unused imports, missing newlines, and overly long lines because they required small, localized edits. The harder issues were security-related findings such as weak hashing, predictable PIN generation, and shell command execution because the fix needed to preserve the program's behavior while reducing security risk.

Q2. How did Pylint, Flake8, and Bandit differ in the issues they detected?
Pylint highlighted code-quality and maintainability concerns, including unused names, missing docstrings, mutable default arguments, and broad exception handling. Flake8 focused on style and formatting issues such as line length and unused imports. Bandit focused on potentially unsafe security patterns, including weak hashing, use of a non-cryptographic random generator, and shell execution.

Q3. How did you verify that your fixes worked?
After making changes, I reran Pylint, Flake8, and Bandit and reviewed their reports. The evidence included in the original PDF shows a Pylint score of 10.00/10 and a Bandit result of "No issues identified." The program was also run from the terminal and displayed ticket information and a successful verification message. The final Flake8 output should be captured clearly if it is required as separate evidence.

Q4. What did you learn about static code analysis?
Static analysis can find issues before code is executed. Using several tools is useful because each tool has a different focus: code quality, style, or security. The reports are a guide for review rather than a substitute for understanding the code; each finding should be checked and fixed in a way that preserves intended behavior.

Q5. How does static analysis improve maintainability and security?
It encourages consistent formatting, clearer exception handling, removal of unnecessary code, and safer handling of security-sensitive operations. This makes the program easier to review and modify, and helps identify risky patterns early in development.

Note: These reflection questions are drafted to cover the lab's stated learning outcomes because the provided lab excerpt did not include the exact reflection-question wording. If your instructor supplied specific questions elsewhere, replace these prompts with those exact questions before submission.